



Diligent Security Policies

Security Department

Revision: 8.6

Date: 2025-09-15

Table of Contents

Document Control	2
1 Introduction	3
2 Security Policies	5
2.1 Scope	6
2.2 Policy	6
2.3 Security Management Structure	6
2.4 Roles and Responsibilities	7
3 Personnel Security Policy	8
3.1 Onboarding and Offboarding	8
3.2 Background Check and Screening	8
3.3 Non-Disclosure Agreement	9
3.4 Training and Awareness	9
3.5 Travel Security	9
4 Acceptable Use Policy	9
4.1 Scope	9
4.2 Expectation of Privacy	10
4.3 Denial of Access	10
4.4 Scope of Right to Monitor	11
4.5 User Responsibilities	11
4.6 Personal Devices	11
4.7 Right to Confiscate and Search	12
4.8 Personal Use of Diligent IT Resources	12
4.9 Violations of Diligent Policy or Law	12
4.10	Security Responsibility
12	
4.11	Information Control
13	
4.12	Phishing and Suspicious messages (email, text message and voice mail etc.)
13	
4.13	Computing Assets
13	
4.14	Software
14	
4.15	Unacceptable Uses
14	

4.16	Mobile Device Acceptable Use	15
4.17	Web Usage Monitoring	16
4.18	Access to Web Site Monitoring Reports	17
4.19	Website Filtering System	17
4.20	External Cloud Storage and Software Services	17
5	<i>Data Protection Policy</i>	17
5.1	Purpose	17
5.2	Clear Desk and Clear Screen	17
5.3	Data Classification and Labelling	17
5.4	Data Protection and Handling	18
5.5	Data Collection and Retention	19
5.6	Data Encryption	19
5.7	Data Transfer	19
5.8	Data Destruction	19
5.9	Recording Policy - Telephone and Video Recording	20
6	<i>Risk Management</i>	20
6.1	Risk Management Methodology	20
6.2	Risk Assessments	20
6.3	Roles and Responsibilities	20
6.4	Risk Reporting	21
7	<i>Access Control Policy</i>	21
7.1	User Accounts	21
7.2	Service Accounts	22
7.3	Passwords	22
7.4	Privileged Access	22
7.5	Remote Access	23
7.6	Contingent Worker Access	23
7.7	Account Revocation	23
7.8	System and Application Controls	23
8	<i>Cloud Computing</i>	23

8.1	Minimum Controls for Cloud Services	24
8.2	Sanctioned and Unsanctioned Cloud Services	24
9	Physical Security Policy	24
9.1	Data Center Physical and Environmental Safety Policy	25
9.2	Teleworker Security	25
9.3	Access to Office Locations	25
9.4	Access to Restricted Areas	25
10	Asset Management Policy	26
10.1	Physical Asset Lifecycle	
26		
10.2	Asset Protection when Traveling	
26		
11	Third Party Management Policy	27
12	Network and System Secure Design and Operational Policy	27
12.1	Secure Network and System Design	
27		
13	System Monitoring and Logging	28
13.1	Security Appliance and Firewall Policy Review	
28		
14	Security Incident Response Policy	28
14.1	Scope	
29		
14.2	Reporting	
29		
14.3	Incident Handling Procedures and Responsibilities	
29		
15	Vulnerability Management Policy	29
15.1	Endpoint Protection	
29		
15.2	Responsible Disclosure Policy	
30		
16	Change Management Policy	30
16.1	Security in Project Management	
30		
17	Secure Software Development Lifecycle Policy	30
17.1	Secure Development Policy	
31		

17.2	Code Promotion and Change Control	
31		
17.3	System Security Testing	
31		
17.4	Technical Review of Applications after Operating Platform Changes	
31		
17.5	Restrictions on Changes to Software Packages	
31		
17.6	Secure System Engineering Principles	
31		
17.7	Secure Development Environment	
31		
17.8	Outsourced Development	
31		
17.9	System Acceptance Testing	
31		
17.10 Data Validation		31
17.11 Secure Code Training		32
17.12 Protection of Test Data		32
18 Secure AI Usage Policy		32
18.1	Secure AI Usage for Internal Corporate Productivity	
32		
18.2	Secure AI Usage in Product Development	
33		
19 Business Continuity Plan and Disaster Recovery Policy		33
19.1	Data Backup	
33		
20 Information Security Reviews and Compliance		34
20.1	Information Security Reviews	
35		
21 Policy Compliance and Enforcement		35
21.1	Annual Security Policy Acknowledgement	
35		
21.2	Policy Enforcement	
35		
22 Exceptions		36
23 Appendix A - Related Documentation		37

23.1	Internal	
38		
23.2	External	
38		
24	<i>Appendix B - Definitions</i>	39
24.1	General Terms	
40		
24.2	Cloud Computing Definition	
42		
25	<i>Appendix C - ISO Mapping</i>	42
25.1	ISO 27001:2022 Clauses and Controls Mapping	
43		

Document Control

This document is confidential to Diligent Corporation. The content may not be published, broadcast or otherwise distributed externally without express written permission of Diligent Corporation.

Document Owner : Monica Landen, CISO

Document Revision History :

Version	Date	Contributors	Comments
8.0	2019-10-16	Security	Full revision from previous version 7.2, began new versioning history with 8.0
8.1	2020-10-13	Security	Made edits to the following areas: 3.1, 3.2, 4.5, 5.4, 5.5, 5.8, 6.3, 8.1, 9.0, 9.4, 10.1, 12.1, 12.2 and 14.1 Added the following sections: 3.5, 7.2, 10.2, 14.2 and 16.3
8.2	2021-10-12	Security	Full revision with addition of Galvanize team and Security Policy
8.3	2022-10-17	Security, HR, ETS, Legal	Annual Policy Update
8.4	2023-09-24	Security, Legal	Annual Policy Update
8.5	2024-09-16	Security, Legal	Annual Policy Update Expanded Artificial Intelligence Policy in section 18.
8.6	2025-09-26	Security, Legal	Transition to new branding template Annual Policy Update

Current Revision	
Document Name	Diligent Security Policy
Version Number	8.6
Data Classification	Company Confidential (C2)
Release Date	2025-10-01
Effective Date	2025-10-01
Current Authors	Monica Landen, Rachel Burley, Bryan Timmerman, Ryan Wilms, Paulo Amaral
Reviewers	Warren Allen, Peter Flynn
Approver	Monica Landen, CISO
Approval Date	2025-09-26 (attachment on file)
Next Review	September 2026

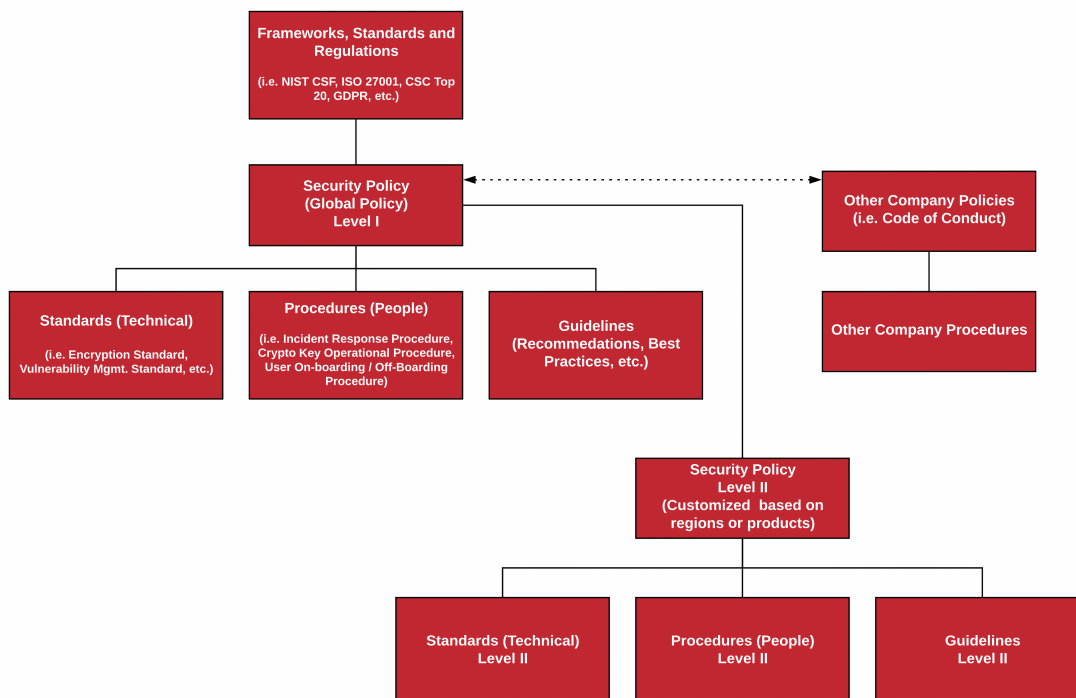
1 Introduction

Diligent Corporation, including its subsidiaries and affiliates, (the “Company” or “Diligent”) has taken great strides to consolidate, enhance, manage, and proactively review its security policies, standards, and procedures. The Company has adopted a framework and methodology that voluntarily complies with and supports the premise of the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF).

The NIST CSF is a widely accepted industry framework used to govern security programs. It provides a non-prescriptive risk-based approach to security and is easily integrated with other standards, procedures and guidelines. NIST CSF is a living framework which is flexible and adaptable to the Company’s changing business requirements, technology, and threats. This framework has also been adopted internationally.

Though the Company uses the NIST CSF as a guiding principle, it has security policies and procedures that encompass several frameworks and standards. Adopting the NIST CSF is not meant to replace other standards and best practices such as ISO 27001 series, CSC Top 20, or NIST 800-53 which are considered more control-centric and prescriptive by design.

Using the NIST CSF and standards, procedures, and guidelines allows the Company to be compliant with many regulations.



The purpose of this Policy document is to:

- Define Diligent’s security framework and supporting methodology
- Define the security organization and its supporting roles and responsibilities
- Identify the underlying governing policies driving this Security Policy, and

- Establish a set of security requirements that the Company must meet

It is the Company's goal to keep its assets safe and its communications and information accurate, confidential, and secure. This document serves as the Security Policy for the Company and should be considered in conjunction with other Company policies, standards, and procedures. All Company employees must understand and acknowledge this policy. This document will be reviewed, updated, and acknowledged on an annual basis or when relevant to include newly developed security standards and will be distributed to all employees and contingent workers as applicable.

2 Security Policies

2.1 Scope

The integrity and confidentiality of business information as well as the availability of information systems are essential to the Company's viability and competitiveness. In the event of a security incident or breach, the Company could suffer serious consequences without effective prevention, detection and incident handling procedures. These consequences could include lost customers, reduced revenue, and a degraded reputation. Security is critical for the Company's management philosophy and business strategy.

2.2 Policy

The Company's security policies (the "Policy") define minimum control measures and practices that all employees and contingent workers who have direct access to Diligent data or facilities must be familiar with and follow.

The Policy encompasses all systems, automated and manual, including systems managed or hosted by third parties on behalf of the Company. It addresses all information, regardless of the format, which is created or used in support of the Company's business activities.

The Policy is applicable to all Company business units and subsidiaries, including acquired entities, operating within and outside of the United States. As such, the Policy must be communicated to all staff and all others who have access to the Company's confidential information.

The primary objectives of the Policy and security program are to:

- Effectively manage exposure to security risks that may compromise Company systems
- Communicate responsibilities for protecting Company information
- Promote and increase awareness of information security within the Company
- Preserve management's operations in the event of information asset misuse, loss or unauthorized disclosure
- Ensure the Company can support growth of the business in a secure manner
- Provide consistent and quality service to customers, employees, and business partners to maintain the Company's reputation for high-integrity business services

2.3 Security Management Structure

2.3.1 Cybersecurity and Risk Management Committee

The Cybersecurity and Risk Management Committee's (the "Committee") primary purpose is to act on behalf of the Company's Executive Management Team in fulfilling the oversight responsibility with respect to the Company's information technology use and protection, including but not limited to data governance, privacy, compliance, cybersecurity, and physical security. Members of this "Committee" are appointed by executive management.

The Chair of the Committee shall report to the Board periodically or when requested by the Board.

2.3.2 The Office of the Chief Information Security Officer (CISO)

The CISO is responsible for:

- Creation, adoption, and implementation of security policies, standards, procedures and guidelines.
- Security strategy and management of security risks related to product development, technology solutions, crisis management, data protection, data privacy and regulatory compliance.
- Program oversight, evaluations, roles, and organizational awareness.
- Security architecture of computer platforms, applications and networks including utilization of cloud technology.
- Security technology and services, including physical and logical access control.
- Cyber threat management, including identification of threats, decision-making, and timely threat mitigating actions.

2.3.3 Technology Risk Management Committee

The Technology Risk Management Committee is comprised of the members from the Product and Technology organization such as software development, product management, and IT teams to focus on the cyber risks associated with products, processes, people, and technology.

2.3.4 Security Council

Diligent's Security Council is a cross-functional group comprised of team members from different parts of the organization such as legal, human resources, product, technology, marketing, customer engagement functions, etc.

The goal of the Security Council is to provide operational oversight and direction for security and privacy relating to the company and our customers. The governance function of the council is required to ensure the company meets our security objectives and fulfills our contractual and regulatory commitments.

The Security Council manages the Company's security program in accordance with the ISO 27001, ISO 27017, and ISO 27018 frameworks. The Council ensures the cyber security risk treatment plan is developed in line with the approved risk management framework's requirements.

2.3.5 Extended Security Resources

The CISO may utilize resources outside of the Security Team to support the Company's security processes. These resources may include Subject Matter Experts (SME) from various departments and outside parties.

2.4 Roles and Responsibilities

The Policy requires employees and contingent workers to apply information security in accordance with established Company policies and procedures.

The office of CISO:

- Is responsible for policy content and for maintaining the relevancy and accuracy of the policies.
- Will review and update the information security policies and procedures documents.

Company Management must:

- Inform all employees and contingent workers of their information security roles and responsibilities, prior to granting access to sensitive information or information systems.
- Provide all employees and contingent workers with guidelines/rules that state the security expectations of their roles within the organization.

Employees and contingent workers must:

- Act in accordance with the policies, including execution of all processes or activities particular to the individual's role(s).
- Protect all information assets from unauthorized access, modification, disclosure, destruction or interference.
- Report security events, suspected events, or other incidence of security policy violation, whether by external, or internal sources.

3 Personnel Security Policy

The Company's employees and contingent workers, such as contractors, consultants and temporary workers who have direct access to Diligent data or facilities, must understand their security responsibilities, and must be suitable for the roles for which they are considered. Further, the Company will follow procedures where onboarding, offboarding and transfer of employees and contingent workers within the Company are performed in an orderly manner.

Business and security requirements for personnel security must be defined and documented within relevant company standards and procedures.

3.1 Onboarding and Offboarding

- Onboarding and offboarding of new employees and contingent workers must follow the processes defined in the relevant standards and procedures. All new user accounts must be requested by HR.
- Management is responsible for defining the scope of responsibility or job description for new hires and for communicating in writing any employee or contingent worker status or classification changes, including but not limited to hire; transfer; reassignment; and termination to Human Resources (HR).
- Management must submit directly to HR in writing an end-date for contingent worker engagements based on the contract or other agreement.
- Contingent workers must have a formal signed contract in place with the Company based on a mutually agreed service level and pre-defined criteria for selection.
- Contingent worker system access must be disabled on the end date pre-determined in the contract or agreement unless management notifies HR in advance in writing. If no end date can be pre-determined, system access must be renewed or disabled according to the timelines defined in the relevant standards.

- Upon employee and contingent worker termination, appropriate assets must be collected, and access must be revoked according to the timelines specified in the relevant standards.
- An exit checklist must be completed upon offboarding of an employee or contingent worker.

3.2 Background Check and Screening

The Company requires appropriate pre-employment screening for all employment candidates or employees in accordance with Company policies to the extent permitted by applicable local laws and regulations. A list of checks must be performed in accordance with the relevant company standards.

- A new background check must be completed for all persons returning to the Company including employees and contingent workers, such as contractors, consultants, and temporary workers if the time elapsed since they left the business is more than 90 days.
- Any contingent worker of the Company who requires unescorted access to Company locations or Company data must complete a background check.
- A background check for a contingent worker from the contracted third-party companies that provides the resources under a service agreement is acceptable.
- In the situation where a commenced background check for employees or contingent workers who have direct access to Diligent data or facilities has not completed, access to Company systems must be limited to non-sensitive systems and roles in accordance with established procedures until the check is complete.
- No employee or contingent worker will have access to C4 - Customer Information or C5 - Client Data, or data in similar classifications per application or product, until a background check is completed. Exceptions to this restriction require a formal policy exception and approval.

3.3 Non-Disclosure Agreement

Employees and contingent workers must have enforceable confidentiality obligations or a signed non-disclosure agreement (NDA) prior to being given access to any Company asset or other privileges to information or information processing facilities.

3.4 Training and Awareness

- All Company employees and contingent workers, where relevant, must receive appropriate Security Awareness Training upon hire, and on at least an annual basis.
- Security awareness testing will be conducted as part of the training to ensure understanding of the material as well as to document the completion of training.
- The Company shall monitor individual information security training activities, including basic security awareness and specific information security training.
- For contingent workers, management may accept awareness training provided by the parent organization if it meets the training requirements required for the role.

3.5 Travel Security

All Employees must follow the Company's Acceptable Use Policy and Travel policies when traveling on behalf of the Company or with Diligent assets. Employees traveling to high-risk



areas (<https://travelmaps.state.gov/TSGMap/>) must take additional precautions. Employees must make every effort to protect themselves and Diligent assets.

Travel to or remote network connections from specific high-risk locations with company assets may be prohibited according to the relevant Company policies.

4 Acceptable Use Policy

4.1 Scope

This policy applies to all employees, temporary and contingent workers, interns and trainees, and all personnel affiliated with third parties (including contractors, partners, and consultants) who access the Diligent IT environment or sensitive information. This also applies to devices connected to Diligent networks including those not owned or operated by Diligent to include:

- E-mail
- Internet
- Computer Hardware
- Computer Software
- Computer Databases
- Software Applications including web accessed applications
- VPN concentrators used for remote access to Diligent network services
- Out-of-Band management devices with modem access
- Personal mobile devices such as cell phones, smart phones, laptops, and tablets

4.2 Expectation of Privacy

Although your access to some parts of the Diligent IT environment requires authentication (e.g., a password), that does not mean that communications (including personal communications) sent over or through the Diligent IT environment are private. In fact, they are not private - your communications; online activity; file creation, access, transfer and saving; and all other uses of the Diligent IT environment are subject to routine real-time and/or delayed monitoring, recording, search and other actions as set forth in this policy.

To the extent permitted by local law, your communications and other activities and use of the Diligent IT environment may be used by Diligent or disclosed by Diligent to third parties for any legitimate business purpose, including, but not limited to:

- investigating possible violations of any laws or company policy and enforcing Diligent policies
- protecting Diligent's IT platform, intellectual property, or confidential information, employee and customer privacy, other rights and property
- responding to government and third-party inquiries; investigating, pursuing, or defending any potential legal claim or potential civil or criminal offence
- pursuing disciplinary actions up to and including termination of employment and legal remedies.

All the above conditions apply regardless of whether your access or use of the Diligent IT environment includes the display of a Notice and Consent Banner ("banner"). When a banner is used, the banner functions as an additional consent and to remind the user of the conditions



that are set forth in this Policy, regardless of whether the banner describes these conditions in full detail or provides a summary of such conditions, and regardless of whether the banner expressly references this Information.

4.3 Denial of Access

Diligent reserves the right at any time to restrict or deny access to the Diligent IT environment without notice.

Diligent has installed or may install software designed to prevent access through Diligent's IT platform to certain categories of websites. This blocking or filtering technology is not a substitute for each employee's duty to ensure that pornographic or racist content, or other offensive or inappropriate material that violates Diligent policies is not accessed via Diligent's IT platform (except in the very limited circumstances in which there is a demonstrable business reason for access to this content, in which case, you must obtain your supervisor's pre-approval.)

In addition, to the extent permitted by local law, Diligent has installed or may install technology (such as automated monitoring tools) to search for words or patterns that help to detect potentially inappropriate activities, such as the unsecured or unauthorized sending of sensitive personal information (including social security numbers, bank account numbers, and credit card numbers) or intellectual property, in which case the transmission of that data may be monitored, recorded, analyzed and/or blocked.

You may not download any software or applications to any Diligent-issued device that would impact the integrity of Diligent's IT platform and/or alter the intended functionality of such device (e.g., jail breaking, re-formatting, rooting, or otherwise altering a device). If you have any uncertainty as to whether any software or application is permissible, please consult with the Diligent IT team.

4.4 Scope of Right to Monitor

To the extent permitted by local law, Diligent reserves the right, without notice:

- to monitor and audit (a) the Diligent IT environment, and (b) your use of the Diligent IT environment, including your access to and use of the Internet and websites accessed or attempted to be accessed.
- to search for or find, access, download, save, transfer, read, copy, print and examine any data created, sent, stored, or received over, on or through Diligent's online connections or the Diligent IT environment, including e-mails, attachments to emails, emails that remain on company computers in temporary Internet folders, and/or other messages.

These rights apply to all applications and electronic communications and files, regardless of whether you use a third-party service provider to access, create or convey the data. This may include, for example, any e-mails sent through personal, password-protected Web-based e-mail accounts via the Diligent IT environment.

These rights may be exercised at any time during your active use of the Diligent IT environment, between uses, and after your access is terminated. Even information that has been encrypted or deleted may be unencrypted, retrieved, recreated and reviewed. Consequently, you have no expectation of privacy regarding communications or data transiting or stored on this information system including when you are engaging in any personal use or when accessing the Internet for personal use.

4.5 User Responsibilities

You are responsible for exercising good judgment regarding appropriate use of the Diligent IT environment in accordance with the Diligent Code of Conduct, the Diligent Information Security Policy and Standards, and other internal policies, rules and procedures, including this Policy, as well as applicable federal, provincial, and local laws.

You should be aware that these rules and policies may change without advance notice at any time. It is your responsibility to remain familiar with the most up to date versions of these rules and policies and to remain in compliance with them. If you have any uncertainty regarding acceptable use, please contact your manager or Diligent Human Resources.

4.6 Personal Devices

You may connect a personal device to the Diligent IT environment (BYOD) provided you register your device with Diligent IT team and have agreed to this policy, which contains a Mobile Device Acceptable Use Agreement. If your personal device has been approved and is used for business purposes (referred to in this Policy as an "approved personal device"), any business-related communications and records on such devices or transmitted by them remain company property in accordance with applicable law and must be protected in line with the Diligent Security Policies and Standards and the Mobile Device Acceptable Use Agreement, which will include password/PIN protection of the device or data, as well as other security controls prescribed by the IT department.

Company data stored on personal devices should be kept in approved applications and not kept in unauthorized locations or commingled with personal data. You are responsible for ensuring device operating systems are kept up-to-date and security patches are applied, and for protecting your device from malware, viruses, and unauthorized access.

You may also be required to allow the installation of Diligent security software that will remotely wipe or erase the company data in the event of loss or theft. As set out in this policy, if your personal device has ever been used for business purposes, you should notify the Diligent IT Helpdesk if that device is lost, stolen, or misplaced.

4.7 Right to Confiscate and Search

To the extent permitted by local law and for the protection of Diligent business information, Diligent reserves the right to confiscate and search any Diligent issued device or any personal device containing any Diligent Information at any time and without prior notice. You agree to make that device accessible to Diligent for such purpose.

4.8 Personal Use of Diligent IT Resources

Diligent's IT platform is intended to be used for work-related purposes. Limited personal use of Diligent's IT resources is permissible as long as it does not interfere with your work responsibilities or Diligent business operations, incur unauthorized costs to the company or violate the law or any company policy. If you have any uncertainty as to permissible personal use, please consult your Manager.

4.9 Violations of Diligent Policy or Law

Internal investigations into possible violations of Diligent policies or the law may be conducted by appropriate company personnel, including, but not limited to the Diligent Security Team, Human Resources Department, or Legal Department, or Diligent may hire and authorize a third party to conduct investigations. All employees are required to fully cooperate with and assist any such investigation when requested by the company to do so.

This obligation may include, among other things, the detention and examination of any personal devices that have been connected to the Diligent network, as well as any Diligent-issued devices. Any failure to cooperate with such inquiry, or any attempt to hinder, obstruct, destroy evidence or data, or otherwise impede such an inquiry, is a violation of company policy.

Most states, provinces and countries have laws regulating the use of mobile communication devices while operating motor vehicles. You agree that you will follow all federal, state/provincial and local laws when you are driving for company business, when you are using a company-issued device, when you are driving a company car and when you are engaged in company business. If state/provincial or local laws are more restrictive than federal laws, you must follow the provincial and local laws.

Most smart phones and other mobile devices now have a camera feature. Your use of a camera in the workplace must not violate any trade secret, confidentiality, or harassment policies or laws. Your department may have additional guidelines regarding the work-related use of your mobile device and/or the use of personal phones at work. If you aren't sure about additional rules, you should ask your Manager.

4.10 Security Responsibility

You are responsible for the security of information, data, accounts, and systems under your control, and you must know and comply with the Diligent Information Security Policies and Standards. Specifically, you:

- must follow the Diligent Security Policies and Standards in your selection and use of your password used to access the Diligent IT environment (including when using your own approved personal device) to minimize the risks of unauthorized access.
- must keep your passwords secure.
- must not share your account or password information with anyone, including other Diligent personnel, your family, or your friends.
- must not disable any security feature, such as anti-malware application, firewalls, group policy, etc..



It is a violation of company policy for you to provide access to Diligent's IT network environment and data systems to any other individual, either deliberately or through failure to secure access to such platform. Failure of access may include using public Wi-Fi without adequate security postures, leaving your workstation unlocked and unattended, allowing physical access for unauthorized personnel to a secured area, etc.

When you connect to the Diligent IT environment from a remote location - or in the case of a business partner connecting from its site - the session must be secure (e.g., connect securely through VPN or other approved method).

4.11 Information Control

To ensure that Diligent Information remains under Diligent's control at all times, you may not store Diligent Information on external platforms, such as web-based (or "cloud computing") services maintained by a third party, or devices maintained by a third party - in either case unless Diligent has a contractual agreement in place specifically allowing for such storage - or on unapproved personal devices.

This rule specifically prohibits the use for company business of an e-mail account that is not provided by Diligent and prohibits storing, sharing or processing Diligent Information with a web-based service that does not have a legally binding agreement with Diligent to protect and manage Diligent data according to standards and procedures that are acceptable to Diligent. Use of unapproved third-party services to transmit or store Diligent Information is also a violation of company policy.

4.12 Phishing and Suspicious messages (email, text message and voice mail etc.)

As a general rule, do not open e-mail attachments or web-links contained within email messages received from unknown senders, as they might include viruses or other malicious code. You should also use extreme caution if you receive a suspicious email attachment or web-link from someone you know. The same concern could arise with text, instant messaging, and voice messaging so use extreme caution here as well. If you suspect a message you received, please report it by following established procedures.

4.13 Computing Assets

- You are responsible for ensuring the security of Diligent assets assigned to you. Any devices containing Diligent Information that are left at Diligent overnight must be properly secured or placed in a locked drawer or cabinet. Laptops and mobile devices carried and used outside of Diligent premises must be secured from loss or theft and should not be left unattended in public places such as airports, hotel lobbies, and restaurants. You must promptly report any loss or theft of any laptop, mobile device or other device containing Diligent Information to your IT Helpdesk.
- All workstations, laptops, and mobile devices must be secured with a password-protected screensaver with the automatic activation feature set to 15 minutes or less. You must lock the screen or log off when the device is unattended. Care should be used when reading or viewing Diligent Information in public places, or where unauthorized personnel could view such Diligent Information.

- You may not interfere with corporate device management or security software installed by authorized Diligent personnel on any Diligent-issued device or on any approved personal device.
- You must report all security incidents or suspected incidents to the Information Security team via the ServiceNow portal, email SecurityNotify@diligent.com, or calling +1 251 319 2341 for urgent assistance. This includes discontinuing the use of any system resources that show signs of being infected by a virus or other malware and report the suspected incident.

4.14 Software

Software applications can create risk in several ways, and thus certain aspects of software use must be covered by this Policy. The company provides the following requirements for the use of software applications:

- Only legally licensed software may be used. Licenses for the company's software must be stored with Diligent IT in a secure location
- Unauthorized software (including free or open-source software) shall not be installed on end-user devices
- Endpoint software must be kept up to date by enabling auto-update functions or installing new patches and releases from the manufacturer as they become available

4.15 Unacceptable Uses

The following activities are prohibited. This list is by no means exhaustive, but it attempts to provide a framework for identifying activities that fall into the category of unacceptable uses of the Diligent IT environment and that are prohibited:

- Use of the Diligent IT environment in any manner that violates this policy, any other Diligent policies or applicable law.
- Accessing systems containing information classified as secret from a non-company device.
- Any attempted bypass or manipulation of Diligent security controls or filters, including, but not limited to, accessing Diligent data, Diligent servers, or Diligent accounts to which you are not authorized, circumventing user authentication to access the Diligent IT environment, or sniffing network traffic.
- Causing a disruption of service to Diligent network resources including, but not limited to, ICMP floods, packet spoofing, denial of service, heap or buffer overflows, and forged routing Diligent Information for malicious purposes.
- Violating copyright law including, but not limited to, illegally duplicating or transmitting copyrighted videos, photos, music, and software.
- Exporting or importing software, technical information, encryption software, or technology in violation of international, regional, or local export control laws.
- Introducing malicious code to the Diligent IT environment including, but not limited to, viruses, worms, Trojan horses, e-mail bombs, spyware, adware, and key loggers.
- Port scanning or security scanning on a production network that is part of the Diligent IT environment unless authorized in advance by the Diligent IT team.
- Executing any form of network monitoring which intercepts data not intended for your own host.

- Sending spam via e-mail, text messages, pages, instant messages, voice mail, or other forms of electronic communication through the Diligent IT environment.
- Forging, misrepresenting, obscuring, suppressing, or replacing a user identity on any electronic communication that is part of the Diligent IT environment to mislead the recipient about the sender.
- Using the Diligent IT environment to post the same or similar non-Diligent business-related messages to large numbers of message boards, newsgroups, or other communication forums.
- Creating or forwarding "chain letters", "Ponzi" or other "pyramid" schemes of any type.
- Sharing of customer-related content, sensitive company information or messages regarding business partners on social networking sites or other public websites.
- Engaging in email, network, Internet/Intranet and other system usage that does not conform to the Diligent Code of Conduct and anti-harassment and discrimination policies.
- Using unapproved remote access methods (i.e., GoToMyPC, TeamViewer, etc.) to remotely access Diligent systems or send Diligent data to unapproved systems (such as home PCs).
- Sending or forwarding messages containing defamatory, obscene, offensive, or harassing statements. An employee should notify their supervisor and /or Human Resource manager immediately upon receiving such a message.
- Sending or forwarding a message that discloses customer or employee personal information without Diligent authorization. This will also include accessing, transmitting, receiving, or seeking confidential information about clients or fellow employees without authorization.
- Sending ethnic, sexual preference or gender related slurs and/or jokes via email.
- Sending or soliciting sexually oriented messages or images.
- Attempting to access or visit websites featuring pornography, terrorism, espionage, theft, or drugs.
- Gambling.
- Using company computing assets to engage in activities that are illegal under local, provincial, federal or international law.
- Participating in activities, including the preparation or dissemination of content, which could damage Diligent's professional image, reputation and/or financial stability.
- Using another employee's password or impersonating another person while communicating or accessing the network or Internet.
- Using anonymous VPN or web proxies from inside the Diligent network to bypass security controls (i.e., TOR).
- Using peer-to-peer (P2P) file sharing software for the unauthorized distribution, display, performance or reproduction of copyrighted work.
- Using artificial intelligence technology in harmful, illegal, or any other ways that violate Diligent's AI Acceptable Use Policy.

4.16 Mobile Device Acceptable Use

This section defines usage and configuration standards for end users with legitimate business requirements to use a private (BYOD) or Diligent-provided mobile device.



Prior to initial use on the Diligent network, all mobile devices must be registered with Diligent IT. IT will maintain a list of authorized mobile devices and related software applications and utilities as needed. Devices that are not on this list may not be connected to Diligent infrastructure. The use of mobile devices must not violate other aspects of this, or other company policies.

This section applies to, but is not limited to, all devices and accompanying media that fit the following device criteria:

- Tablet computers with the following operating systems: iOS, Android
- Smartphones with the following operating systems: iOS, Android, Windows Phone

As part of Acceptable Use, users also agree to the following regarding Mobile Device usage:

- Maintain the default installed, supported and updated operating system on the mobile device. Hacking (jail breaking) a mobile device operating system which is being used to access the Diligent network or store Diligent information is prohibited.
- Immediately (within 24 hours) inform the Diligent IT Helpdesk if a mobile device is lost or stolen.
- Notify the Diligent IT Helpdesk if a mobile device is no longer to be used to access the Diligent network or store Diligent information.
- Immediately inform the Diligent IT Helpdesk of a new mobile device that is to be connected to the Diligent network or to be used to store Diligent information.
- Make no attempt to modify or circumvent security configuration settings resulting from Diligent policy as a condition of using the device to receive and store Diligent information.
- Ensure that no Diligent Confidential information is stored on the mobile device without being encrypted. Secret information must never be transmitted to or stored upon mobile devices.
- Employ reasonable physical security measures to safeguard the device while not in use.
- Maintain full encryption on the mobile device at all times.
- Maintain legitimate licenses for all software applications.
- Install all operating system and application updates.
- Ensure that a Personal Identification Number (PIN) with a minimum of 4 digits or similar identification protection is needed to obtain access to the mobile device
- Contact the Diligent IT Helpdesk if any of the above listed controls malfunctions or if there is any suspicion of the mobile device being compromised.
- Present the device annually for inspection if requested to ensure that security controls are properly in place.
- Allow Diligent the installation and use of 3rd party anti-malware, password management, encryption, asset management and other similar security and monitoring software
- Allow Diligent to limit applications installed on the BYOD device, including deleting applications that are deemed malicious or inappropriate
- Allow Diligent to remotely delete information on the mobile device if lost/stolen or if you leave employment at Diligent.

Note: Remote deletion might inadvertently delete user information on the mobile device. You may elect to bring devices to IT before your final day to get Diligent data wiped to avoid remote wiping of data. It is recommended that you maintain backups of personal information and settings.

4.17 Web Usage Monitoring

The Diligent IT team will monitor Internet website use from all computers and devices connected to the corporate network. Monitoring tools will record source IP Address, date, time, protocol and the destination site/sever as a minimum. The monitoring system will also record the User ID of the individual that initiated the connection.

4.18 Access to Web Site Monitoring Reports

The Diligent Security Incident Response Team will have access to website monitoring reports in order to respond to security incidents. Website monitoring information that identifies specific user's activities will only be made available to managers or other authorized officials upon formal, written request from a Human Resources Representative for investigations relating to Diligent Security Policy or Code of Conduct violations.

4.19 Website Filtering System

Diligent will block access to Internet websites and protocols that are considered high-risk for phishing, malware, spyware, social engineering, hacking tools and other dangerous code. Diligent will periodically review blocked sites. If a blocked site is mis-categorized or can be demonstrated to be needed for business purposes, exceptions can be requested on a case-by-case basis by contacting the Diligent IT Helpdesk.

4.20 External Cloud Storage and Software Services

The following controls must be observed regarding obtaining and using cloud storage and other cloud software services which are not managed by Diligent and/or are located outside the Diligent network environment:

- Users must not obtain or use external cloud storage and software Services for Diligent business without obtaining permission from their immediate manager and the Diligent IT team.
- All purchased external cloud storage and software services must follow the third-party engagement process before use to include official contract review, security risk assessment including an Information Security approval.

5 Data Protection Policy

5.1 Purpose

The Company will protect the security and integrity of data at rest and in motion regardless of its physical or logical location.

Business and security requirements for data protection must be defined and documented within relevant standards and procedures.

5.2 Clear Desk and Clear Screen

The Company Clear Desk and Clear Screen Policy requires all employees and contingent workers to:

- Place sensitive documents, portable computing devices, and portable storage devices in a locked space during extended periods of time away from their desks.
- Lock screens on all computing devices (requiring a password or pin-unlock to resume access) when away from the device.

5.3 Data Classification and Labelling

The Data Owner, the individual that creates the data, is responsible for assigning classifications to their information assets.

Company information is classified according to the 5 distinct data classifications:

- **C1 - Public:** Public or Non-Classified Information (i.e., data is not deemed confidential and can be shared publicly without any negative impact to the Company. Examples, public facing marketing materials, presentations, general reports, etc.
- **C2 - Confidential :** Confidential Information: Information is deemed confidential within the Company and protected from unauthorized external access. Should access be compromised, the following could occur financial loss, decline in operational effectiveness, gain to competitors and / or loss of consumer confidence. Examples: legal documents, contracts, financial reports, marketing plans, internal product information, design document, unpublished product roadmaps, technical documents, security information, etc.
- **C3 - Regulated Data :** Regulated data: PII (Personally Identifiable Information), NPI (non-public information) under the protection of laws and/or regulations (GLBA, NYS DFS, HIPAA, GDPR etc). Unauthorized, external or internal access to this data class would be critical to the Company. Examples, social security numbers, personal financial data, health information, biometric data, etc.
- **C4 - Customer Information :** Any information pertaining customer's identity such as company names, site names, customer contact information, email addresses, phone numbers etc.
- **C5 - Client Data :** Any data uploaded or provided by customers into Diligent's platforms, including public data before they are made public by customers. Examples include board meeting materials, unpublished earning reports, encryption keys, entity ownership information, internal memos or messages, audit project names, uploaded file names, uploaded file contents, finding records, risk data, etc.

The Company defines any non-Public Information to be sensitive data. Any data classified at a level of C2 or above should have visible or digital labelling defining its classification level.

5.3.1 Product or subsidiary specific data classification

- Each subsidiary, application, or product may specify data in similar classifications as those above where required.
- Where technically feasible, the Diligent data classification shall be implemented.

5.4 Data Protection and Handling

- Employees and contingent workers must follow the current Company approved procedures for being granted access to sensitive data.
- Contingent workers requiring access to sensitive data must use systems that conform with the relevant Company standards for encryption and authentication.
- Storage, handling, and disposal of information must follow relevant documented standards in accordance with the data classification scheme.
- All sensitive data stored in hard-copy form must be secured at all times or destroyed.
- Unless approved by the Customer, C5 - Client Data should not be printed or copied onto paper to avoid potential data leakage.
- All sensitive data stored in electronic form should be encrypted at rest and in transit where supported by applicable technologies.
- Any cloud service provided by the Company, whether dedicated environment or multi-tenancy, must provide logical or physical data isolation for C5 - Client Data.
- Any information received or obtained by any employee and contingent worker in error (including accidental disclosure) must be deleted or destroyed and reported to SecurityNotify@diligent.com immediately.
- Sensitive information must not be sent through any form of unapproved or insecure electronic communications, for example unencrypted emails, collaboration systems, social media, etc.
- Disclosure of sensitive information to any external party is only permitted after a confidentiality agreement has been properly executed.
- When traveling to high-risk areas (<https://travelmaps.state.gov/TSGMap/>), employees must take extra precaution for data protection as specified within the Security Policies document.
- Suspicion or knowledge of unauthorized disclosure of sensitive data must be reported to SecurityNotify@diligent.com immediately.

5.5 Data Collection and Retention

- The Company must obtain data in a specific and lawful manner and process it fairly and lawfully.
- Employees and contingent workers must follow the Company's Privacy Policy and the Record Retention and Destruction Policy.
- Data should not be retained for longer than necessary.

5.6 Data Encryption

Encryption methods shall comply with the requirements defined in the relevant cryptographic standards. Encryption requirements shall be reviewed annually and upgraded as technology allows in response to emerging technology risks.

The use of proprietary encryption algorithms is not allowed for any purpose, unless reviewed by qualified experts outside of the vendor in question and approved by the CISO. The Company is responsible for compliance with relevant legislation and regulations of the encryption export regulations.

Where possible, central key management techniques will be employed to ensure that the company maintains access to its data. Access to keys used to encrypt data is restricted to authorized personnel.

- C3 data and above must be encrypted at-rest and in-transit unless other compensating controls are in place.
- The Company employs industry standard data encryption technologies as described in the Company's Encryption Standard.

5.7 Data Transfer

Data will only be transferred between the Company and a third party when there is a regulatory, statutory, or contractual obligation, and only when the transfer of data is performed in accordance with the Data Protection and Handling Policy. Data transferred within Company systems will be protected according to its classification.

5.8 Data Destruction

All sensitive data must be disposed of in a manner that meets industry best practice, and regulatory and contractual obligations. Requirements for disposal must be documented in relevant standards and procedures.

Employees and contingent workers must place sensitive printed material in shredding bins when they are no longer needed.

All media used to store sensitive data must be sanitized according to the relevant standards. Data destruction must conform with the Company's Record Retention and Destruction Policy and related technical standards and procedures.

5.9 Recording Policy - Telephone and Video Recording

Diligent is committed to protecting personal information and conducting its business in compliance with privacy and data protection laws. The correct and lawful treatment of personal information will maintain confidence in Diligent as an organization and provide for successful business operations. Diligent's Legal Team maintains a company-wide Recording Policy, the purpose of this Policy is to establish Diligent's rules and procedures for recording telephone calls and video conferences between Diligent employees and third parties (i.e., customers, prospects, partners, vendors etc.).

6 Risk Management

The Risk Management Policy governs the confidentiality, integrity, and availability of Company assets by identifying, assessing, and rating risks. The Company manages risks appropriately through treatment plans. Risk management of the Company's assets must ensure appropriate controls are used to manage risk.

6.1 Risk Management Methodology

Risk is the probability and impact of a threat or vulnerability negatively affecting an asset. The risk rating is determined by scoring the likelihood of the threat or vulnerability occurring and the effect that the threat or vulnerability has on the organization.

Identified risks must be treated in one of four ways: Mitigation, Acceptance, Transfer, or Avoidance. The criteria for selecting the appropriate treatment plan are defined in the relevant risk management standard.

6.2 Risk Assessments

Risk assessment is the primary tool for identifying, analyzing, and reporting information risks. Formal technical risk assessments must be conducted at least annually on critical information systems, and at the discretion of the CISO. Assessments must follow the methodology outlined in the relevant company standard and must include an evaluation of threats, assets, vulnerabilities, and associated risk.

6.3 Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer (CISO)	▪ Drive overall culture of information risk management and own the policy and program ▪ Authorize risk assessments and their scope
Security Team	▪ Oversee the execution of regular technical risk assessments ▪ Maintain and improve the information risk management strategy and supporting framework ▪ Manage the Information Security Risk Register ▪ Advise Risk Owners in defining and implementing appropriate treatment plans ▪ Ensure risk management activities satisfy internal and external requirements
Diligent Management	▪ Conduct formal or informal business-level risk assessments ▪ Own individual risks identified within their business units ▪ Ensure staff in their business units comply with this policy and foster a culture where risks can be identified and treated ▪ Complete an annual Business Impact Analysis (BIA) form with information for risk management and business continuity activities or planning.
Diligent Staff	▪ Comply with risk management policies and procedures ▪ Own remediation plans assigned by risk owners

6.4 Risk Reporting

Risk related metrics are captured on a predetermined basis as a Key Risk Indicator (KRI). Risks are evaluated based on the company's risk tolerance. Risks exceeding the company's tolerance must be escalated to the appropriate Risk Management Committee.

7 Access Control Policy

Access Control is the management of admission to Company systems or to physical / virtual resources. It grants authenticated user access and certain privileges to systems, resources, or information. Access control includes authentication, which proves the identity of the users.

Access to all systems must follow the principles of:

- Least privilege,
- Separation of duties, and
- Role Base Access Control (RBAC), where applicable.

Access to information systems and services must be consistent with business needs and be based on security requirements, to ensure that information and information systems are available for authorized use and protected from unauthorized use. Different systems may have specific, documented access control standards, but all must follow the principles defined in this section.

7.1 User Accounts

- There must be a formal process for granting, modifying, and revoking user access to all information systems and services.
- Individual user access to Company's systems must be protected by unique user IDs. Shared accounts are not permitted without a policy exception.
- Separate accounts must be created for personal corporate and system administrative functions.
- Management must approve access to any system and the level of rights within that system.
- User account IDs should not contain data that could reveal sensitive information.
- Periodic reviews of privileged user accounts must be implemented to verify control over access rights in accordance with timelines defined in the relevant company standards.
- Business or system owners must review system accounts and permissions on a periodic basis.

7.2 Service Accounts

- Service accounts are used for machine-to-machine connections and should not be used by individuals.
- The same service account username and password must not be used in both production and non-production environments.
- Service accounts credentials should be traceable, and the purpose of the account should be identified to ensure appropriate use.
- With the exception of required service accounts or OS/device-specific accounts, all user accounts and user IDs must not be shared.

- Service account passwords should be stored in company approved vault systems or other secret management platforms and should be rotated when someone with access to the password is offboarded.

7.3 Passwords

- Access to Company's systems must be protected by unique passwords.
- Accounts in multiple domains or accounts in non-production and production environments must not have the same password.
- Non-federated user accounts should use a different password or passphrase for each system.
- Local accounts must not use the same password as domain accounts.
- Users must not share their password or other access information, such as PIN.
- Password policy, including length, complexity, history, and age requirements, must be implemented in accordance with the relevant company standards.
- Initial passwords must expire according to the relevant company standard.
- Initial passwords or password resets for users must be unique and communicated to the user securely.
- Users must change initial password or passwords that have been reset at next login.
- If an employee or contingent worker suspects that their account credentials have been compromised, they must change their password immediately and notify the Security Team (SecurityNotify@diligent.com).
- System or Service accounts that use a password vault for authentication to production systems (no manual entry of password) do not require 90-day password rotation or failed password lockouts; instead, such accounts shall have their passwords rotated on a yearly basis, or at an interval defined in a relevant company standard.

7.4 Privileged Access

- All administrative accounts must be renamed, and default passwords must be changed on all computers, network servers, routers, firewalls, switches and related appliances.
- Multi-factor authentication must be used for all system administrator accounts unless other compensating controls are in place and a formal policy exception is submitted and approved by the appropriate management stakeholders.
- Password policy for privileged users, including length, complexity, history, and age requirements, must be implemented in accordance with the relevant company standards.
- Privileged users must use Company-managed assets when performing privileged tasks.
- All administrative activity in production environments should be conducted through an approved privileged account management system.
- All activity for privileged accounts must be logged and available for review.
- Dormant privileged accounts must be reviewed periodically and disabled accordingly.

7.5 Remote Access

- The Company network must be accessed by Company-approved remote access methods and configured with multi-factor authentication enforced.

- Remote access to production systems must be approved by Management and tracked in the Company change management system.
- When a third party or vendor requires remote access for technical support via collaboration tools, the employee must initiate the connection and supervise the remote access session at all times.
- Appropriate controls must be developed for remote access, along with relevant standards and procedures, to minimize the risk of theft of equipment and information, unauthorized disclosure of information, and unauthorized use of internal Information Systems.

7.6 Contingent Worker Access

- Outsourced maintenance or consulting personnel must be restricted to systems according to the roles and responsibilities defined in the contract or Statement of Work (SOW).
- Contingent workers requiring physical access to sensitive or restricted areas must be escorted.

7.7 Account Revocation

- Access to Company systems must be revoked based on notification provided by HR.
- Information system accounts must be disabled in a timely fashion in accordance with the specific timelines defined in the relevant company standards.
- Business owners are responsible for removing access to all systems under their control.
- Company equipment (laptops, mobile devices, etc.), including physical access devices (fobs, cards, keys, etc.), must be returned according to the User Offboarding Procedure.

7.8 System and Application Controls

- Inactive sessions must be disconnected, where possible, after a period of inactivity to minimize the risks of access to systems via unauthorized use of established sessions.
- Concurrent sessions for information system accounts should be limited to provide additional security where operationally feasible. Maximum limits shall be defined in the relevant standards.
- Strict control must be maintained over access to program source code and associated items (such as designs, specifications, verification plans, and validation plans) to prevent the introduction of unauthorized functions and to avoid unintentional changes to operational system software.

8 Cloud Computing

The policy pertains to all external cloud-based services, e.g., Software as a Service (SaaS), Infrastructure as a Service (IaaS), Platform as a Service (PaaS), which are not hosted or managed at a Company facility. The usage of Cloud Computing may present significant risk to the Company, especially when customer data may be shared with third-party provider. Care should be taken to follow all relevant Company policies and standards when considering current and future usage of Cloud Computing services.

8.1 Minimum Controls for Cloud Services

- Use of cloud computing services must be formally approved according to the Vendor Management Procedure before use.
- The use of cloud-based services must comply with Company's existing Acceptable Use Policy.
- Where feasible cloud resources should be hardened to the relevant baseline configuration standard.
- Cloud services used by the Company should be inventoried, categorized and updated according to the relevant company standards.
- Where applicable, cloud services used by the Company should be integrated with federated identity management.
- Where possible, multi-factor authentication (MFA) must be used for a cloud service based on the security posture of the service, as identified via a risk assessment.
- A business owner must be identified for each cloud service.
- The business owner must approve and/or grant access to their cloud services and the level of rights within that service.
- The business owner is responsible for account life-cycle activities for non-federated cloud services.
- Privileged account management for cloud services must follow the requirements outlined in the relevant company standards.
- Any cloud service used by the Company must provide encryption at-rest and in-transit.
- The service provider should demonstrate security monitoring of the hosted service is being performed.
- Where possible, relevant user and audit logs should be collected in a format exportable to the Company's SIEM tool.

8.2 Sanctioned and Unsanctioned Cloud Services

- Sanctioned cloud services must be approved by the Company, licensed, and managed. Sanctioned services must undergo a formal approval process involving a risk assessment.
- Unsanctioned cloud services are prohibited. Business Owners will be held accountable for the use and potential impact of unsanctioned cloud services.

9 Physical Security Policy

All locations to which company personnel report for regular employment and/or locations where company information is processed will be subject to this policy.

The Company requires that all office locations and data centers must, where possible, have the following minimum set of physical access controls:

- Facility-perimeter doors locked outside of normal business hours requiring either card-access or keys.
- Office/general-area perimeter door must be locked at all times, using either card-access or keys.

- Access logs must be kept for the retention period defined in the relevant company standards.
- Burglar alarm monitored 24x7 by an independent monitoring company with appropriate Company employee contacts for notifications.
- Office/general-area perimeter door card-access system to ensure that each Diligent employee is uniquely identified upon entering the office/area.
- Office/general-area CCTV monitoring (and recording equipment) of all ingress-egress doors as well as any elevator/stairwell areas.
- Facility-perimeter sign-in/visitor provided by the building owner where available.
- Facility-perimeter security guards on-site provided by the building owner where available.

9.1 Data Center Physical and Environmental Safety Policy

Diligent requires that all data center locations containing production systems provide the following physical and environmental security controls:

- All systems must be protected from risks from environmental hazards such as temperature, condensation, and water damage.
- Production systems must be hosted in Data Centers that provide physical protection from external and environmental threats.
- All systems must be protected from power disruption with UPS, backup power generation, and redundant power feeds.
- Power and network cabling must be located as to be protected from data interception or physical damage.
- Environmental safety and security equipment at each location must be properly maintained to ensure its availability and integrity.

9.2 Teleworker Security

Teleworkers must ensure the physical and logical security of their devices:

- Access to the Company information systems must be conducted using Company issued or approved computing devices.
- Teleworkers must follow the Company's Acceptable Use Policy.
- Information containing Company or customer data must be handled according to the relevant company standards for data protection and handling.
- Company assets when not in use for an extended period of time should be locked or stored out of view.
- Teleworkers must connect from secure, password-protected networks, or over VPN, avoiding insecure or public networks such as cafe or airport Wi-Fi.

9.3 Access to Office Locations

All Company employees and contingent workers must be issued access cards for access to the office and other restricted areas as required and approved by management. Lost or damaged access cards or ID badges must be reported to the Security Team as soon as possible via email to SecurityNotify@diligent.com.

- Unauthorized persons are prohibited from gaining access to Company office locations by following an authorized person.

- All visitors, including personal guests, must sign in at Company offices and be escorted by Company personnel. Visitors must be issued a visitor identification badge where applicable.
- Facilities must be notified (Facilities@diligent.com) of interoffice visits in advance where applicable. Temporary access cards should be registered to an individual.
- Temporary access cards and visitor cards should be returned after use or remotely disabled.

9.4 Access to Restricted Areas

Restricted areas are defined as all areas where Company equipment is located in a physically separated space from general areas. These may include tech closets, secure storage areas or similar rooms within Diligent facilities. It also includes data centers where Diligent assets are stored. The following minimum set of physical access controls apply to these areas:

- Only authorized personnel are given access to restricted areas.
- All restricted areas doors must be locked at all times.
- Restricted area doors controlled by swipe card or FOB and/or those with cameras must record events of entry.
- Restricted area doors controlled with physical keys must have a log of individual(s) who have keys issued to them.
- Perimeter doors and cameras must record events of entry, where applicable.
- Perimeter access must apply Two-Factor Authentication, where applicable.
- Data Center access must follow the Change Management Process.

10 Asset Management Policy

10.1 Physical Asset Lifecycle

The Company will clearly identify, inventory, and maintain all assets. The asset inventory will include key information such as: type, location, license information, classification, and ownership. Owners are responsible for maintaining appropriate asset information. This inventory should record sufficient information to facilitate system planning, asset lease management (if applicable) and asset recovery in the event of loss or destruction.

Rules for the acceptable use of information assets for official Company business must be identified and documented. All employees and contingent workers must agree to and abide by the Acceptable Use Policy.

- **Asset On-boarding** : Minimum requirements for asset on-boarding include mandatory inventorying and tagging, either physically or digitally, based on asset type.
- **Asset Provisioning** : All assets must be provisioned in accordance with employee or contingent worker job responsibilities. When provisioning an asset, an owner must be assigned. Asset owners may be individuals or a department head.
- **Asset Transfer** : Asset Transfer is defined as the reassignment of existing asset(s) to a different employee or contingent worker. The IT department is responsible for assessing the condition of the equipment to determine the status and best means of disposal or redistribution. When an asset has been marked for transfer, the asset must be reviewed then subsequently digitally sanitized by an approved data erasing process.

- **Asset Transport** : Any corporate or production assets that are physically transported from one location to another must be protected so that sensitive data or configurations cannot be accessed by unauthorized personnel during transport. If encrypted data is transported, then the keys must be transported separately.
- **Asset Removal** : Employees and contingent workers are prohibited from removing unauthorized assets from Company offices or restricted areas.
- **Asset Disposal** : The IT department is responsible for assessing the condition of the equipment to determine the status and best means of disposal. Adequate controls must be followed during the disposal of equipment to prevent the compromise of information. These are defined in the relevant company standards.

10.2 Asset Protection when Traveling

Employees traveling, especially to high-risk areas (<https://travelmaps.state.gov/TSGMap/>) must follow the Company's Acceptable Use and Telework policies and should consider the following while traveling:

- Avoid downloading new applications to electronic devices while on travel
- Ensure two-factor authentication is enabled for all electronic devices
- Enable Company-provided VPN services before the trip for electronic devices to ensure an established and secure connection is used
- Maintain awareness within your surroundings and do not leave any devices unattended at any time
- Ensure device connections are non-discoverable and do not enable auto-connection functionality on mobile devices
- Perform a physical inspection of your equipment upon return, report any suspicious finding to SecurityNotify@diligent.com

11 Third Party Management Policy

All vendors with access to sensitive systems or information must undergo a risk assessment to determine vendor classification, security, technical, and contractual requirements. The Security Team is responsible for providing recommendations for reducing vendor risk when an assessment is requested. Business owners are responsible for following the recommendations to reduce risk and accepting the residual operational and security risks associated with outsourcing.

All vendors that pose sufficient risk, as per the relevant Third Party Risk Management standard, must undergo a documented review to ascertain whether they are able to provide their respective products or services in a manner that is commensurate with Company standards for Information Security, Data Privacy, and Confidentiality.

Documented Vendor Management standards must be followed throughout the third-party management lifecycle.

Based on the relevant Vendor Management standard, the following may be performed:

- Pre-contract due diligence on the prospective vendor
- Review of completed security questionnaires, security compliance audit reports, registrations, and third-party attestations as applicable

- Assignment of vendor risk rating based on residual risk
- Critical vendors must be reviewed based on relevant standard.

12 Network and System Secure Design and Operational Policy

12.1 Secure Network and System Design

Environment Segregation and Separation principles must be followed with respect of application, system or infrastructure design. All Company networks passing sensitive data must have authentication of users. All Company wireless networks must have industry-acceptable encryption and follow the relevant baseline configuration standards.

- **Segregation of Duties** : To reduce the risk of accidental or deliberate system misuse, separation of duties or areas of responsibility should be implemented where practical. Whenever separation of duties is difficult to achieve, other compensatory controls such as monitoring of activities, audit trails and management supervision must be implemented.
The segregation of duties rule applies to both application design and infrastructure design such as network and system segmentation.
- **Production and Non-Production Environments** : Production, Development, and Test Systems, where resources permit, should be logically and / or physically separated. Where these distinctions have been established, development and test roles should not have access to production systems. Role-based access controls that acknowledge when personnel have access to production systems must be supported based on agile workflow use cases.
- **Corporate and Guest Networks** : The Company's corporate networks can only be accessed by authenticated employees and contingent workers with Company issued devices. Role-based access controls must be supported on Company networks. Guests are prohibited from accessing the Company's corporate network and may only use the Company's designated Guest network.

13 System Monitoring and Logging

Systems and applications must be monitored to detect outages, security events and deviations from previously established baselines.

Standards for monitoring the use of information processing facilities must be established and the results of the monitoring activities reviewed regularly to ensure that users are performing only activities that have been explicitly authorized and that suitable events are being monitored. Faults must be logged, analyzed, and appropriate action taken.

Centralized log management should be utilized where possible. Centralized logs must be kept secure and retained for the period specified in the relevant company standards.

Logs must be continuously monitored to enable detection and response to security events and intrusions (e.g., automation of log monitoring and event alerting). On-demand capture of

network traffic shall be implemented, where operationally feasible, at network security boundaries and within networks housing sensitive information.

The following controls must be in place:

- Unplanned system outages, based on the risk factors, exposure, and impact, must be logged, reviewed, and investigated as security incidents.
- Logging facilities and log information must be protected against unauthorized modification and unauthorized access.
- System administrator and system operator activities must be logged, and the logs protected and regularly reviewed.
- All information system equipment must have internal clocks synchronized for accurate recording.

13.1 Security Appliance and Firewall Policy Review

Security appliances or other security control systems such as firewalls, content filtering systems, end-point protection solutions, secure email gateways etc. should be reviewed as per the relevant company standards to ensure the configuration of systems and technical policies remain valid and appropriate.

14 Security Incident Response Policy

The Company will manage security incidents including proper identification, containment, investigation, and remediation.

14.1 Scope

This policy defines the actions required for reporting or responding to information security incidents involving the Company's information and/or information technology resources to provide effective and consistent reporting, handling, and remediation of such events. It also provides the processes for documenting, reporting internally and externally, and communicating incidents so that organizational learning occurs. Finally, it establishes responsibility and accountability for all steps in the process of addressing computer security incidents.

The scope of this policy includes any potential or actual breaches to the Company's corporate information technology resources as a result of intentional or unintentional acts. This includes, but not limited to, computer systems, email, network, corporate Internet connections and physical facilities. This policy applies to all employees and contingent workers who have access to company-owned or company-provided infrastructure (i.e., computers, mobile device, etc.) or require access to Company's network and/or systems.

14.2 Reporting

- If a security incident or information security weakness is discovered or suspected, users must treat the suspected security incident as confidential and report the incident immediately to their respective supervisor and email the Company's Security team via SecurityNotify@diligent.com.

- Users must not withhold information related to a security incident or interfere with an investigation.

14.3 Incident Handling Procedures and Responsibilities

While the Policy governs how Security Incidents are defined and to be managed, a detailed Security Incident Response Plan must be followed by the relevant stakeholders.

15 Vulnerability Management Policy

Security vulnerabilities in operating systems, applications, drivers and hardware devices can provide attackers with opportunities to gain control of Company computers and network devices. The Company requires a proactive vulnerability management plan be implemented on corporate and production systems. Vulnerabilities must be remediated with appropriate and adequate mitigation and in the most expeditious manner possible that is appropriate to the level of vulnerability identified. Vulnerabilities that could result in immediate confidential data exposure or system compromise must be remediated according to the timeline established in the relevant vulnerability management standards.

When patches are delayed or not available for security vulnerabilities, other compensating controls must be implemented.

Operating systems, applications, and hardware devices that are no longer supported by their vendors and have known vulnerabilities should be updated to a vendor supported version or replaced with an alternative vendor supported version, or have other compensating controls implemented so that security vulnerabilities in those software and hardware can be managed.

15.1 Endpoint Protection

All production and corporate systems (including end-user computing devices such as laptops and workstations) are required to follow the relevant company baseline configuration standard and have appropriate End Point Protection, anti-malware software, installed, configured, and running unless other compensating controls are in place.

- Anti-malware software must be centrally managed (both for production systems and corporate systems).
- Anti-malware systems must update their Indicators of Compromise (IoC) at least daily.

15.2 Responsible Disclosure Policy

Software security researchers are increasingly engaging with Internet companies to hunt down vulnerabilities. Diligent works with security experts across the globe to stay up-to-date with the latest security techniques.

The Diligent's Responsible Disclosure Program applies to security vulnerabilities found within Diligent's public-facing online environment. This includes, but is not limited to, Diligent's websites, exposed APIs, mobile applications, and devices. For the protection of our customers, we do not disclose, discuss or confirm security matters until comprehensively investigating, diagnosing and fixing any known issues.



Diligent's Responsible Disclosure Program is governed by this Policy and specific implementation of the Responsible Disclosure Program is outlined in the Diligent Responsible Disclosure Plan owned by Application Security Team.

16 Change Management Policy

Changes to business-critical information processing facilities and systems must be logged and controlled to minimize the risks of system or security failure. Documented change management standards and procedures must be in place and followed for production, testing, and corporate environments.

The change management process should consider:

- Identifying and recording significant changes.
- Assessing the potential impact, including the security impact, of the change.
- Obtaining necessary management approval(s).
- Planning and testing changes including documenting fallback procedures.
- Communicating change details to relevant personnel.
- Evaluating that planned changes were performed as intended.

A ticketing system must be used to document the change management process and records must be retained per the appropriate retention standard.

16.1 Security in Project Management

Security requirements for new, or enhancements to existing, information systems should be identified and addressed as part of all projects. These requirements should be reflected in the relevant company standards and procedures.

17 Secure Software Development Lifecycle Policy

The product development team must follow a documented and well-defined Software Development Lifecycle (SDLC) process that suits it. The Secure SDLC (S-SDLC) policy defines the proper measures that must be taken during all phases of the SDLC to minimize security risks. This is accomplished during all phases of the SDLC by properly classifying data, identifying threats, ranking risks, and implementing countermeasures.

17.1 Secure Development Policy

Rules for the development of software and systems must be established and applied to development practices within Diligent.

17.2 Code Promotion and Change Control

Code promotion to production requires management approval, testing, and compliance with the documented change control process.

17.3 System Security Testing

Testing of security functionality must be carried out as part of the development lifecycle.

17.4 Technical Review of Applications after Operating Platform Changes

The operation and security of applications must be reviewed and tested whenever changes occur to the underlying operating system to ensure that the operation of the application is not compromised.

17.5 Restrictions on Changes to Software Packages

Vendor supplied software must be used without modification unless there is an essential need to make modifications. Appropriate controls must be applied, to minimize the risks of data Integrity being compromised and to avoid potential problems of ongoing support.

17.6 Secure System Engineering Principles

Principles for engineering secure systems must be established, documented, maintained, and applied to any information system implementation efforts.

17.7 Secure Development Environment

Diligent must establish and appropriately protect secure development environments for system development and integration efforts that cover the entire system development lifecycle.

17.8 Outsourced Development

All outsourced software development must meet specified code development security requirements.

17.9 System Acceptance Testing

Acceptance criteria for new information systems or upgrades must be established and suitable tests of the system carried out prior to acceptance, to minimize the risks of system failures following upgrades or new software implementation.

17.10 Data Validation

Input data to applications must be validated during development or modification to ensure that data input is correct and appropriate. When developing, or changing applications, data validation checks must be incorporated into applications to minimize the risks of corrupting information through processing errors or deliberate acts. Data output from applications must be validated to ensure that the processing of stored information is correct and appropriate to the circumstances.

17.11 Secure Code Training

Developers and development managers must receive periodic training in secure code development practices to minimize security vulnerabilities in Diligent software.

17.12 Protection of Test Data

Test data must be carefully selected, sanitized, protected, and controlled to minimize the risks of unauthorized access to information where it is held in the form of test data derived from production.

18 Secure AI Usage Policy

Artificial Intelligence (AI) includes systems trained to hold human-like conversations and to understand information based on user input and what is published on the internet. Employees and Contingent Workers should follow the requirements in this policy to ensure appropriate usage of AI systems and reduce the likelihood of data confidentiality or integrity risks.

18.1 Secure AI Usage for Internal Corporate Productivity

Employees and contingent workers must evaluate if intended usage of AI systems may compromise Diligent intellectual property, the confidentiality of Diligent or Diligent customer data, or the privacy of Diligent employees and customers.

Employees and Contingent Workers are responsible for ensuring they:

- Do not share confidential Diligent data (C2) or Diligent customer data (C4, C5) with generative AI tools unless the tool is procured by Diligent specifically for that purpose.
- Review AI responses for accuracy and reliability and do not trust that the tool will be accurate or correct.
- Some AI tools are prone to “hallucinations” (a confident response by an AI that does not seem to be justified by facts). This is true of fact-based statements as well as code generation.
- In general, avoid sharing personal information of colleagues or customers with AI tools unless an appropriate vendor agreement is in place.
- Comply with Diligent’s AI Acceptable Use Policy

Usage of AI systems must also comply with the requirements for general acceptable use, third party management, encryption, access control, and all other applicable requirements described in the Diligent Security Policy.

Engaging with AI vendors and systems is subject to standard third-party risk assessment and due diligence. Depending on risk, certain AI vendors may require additional review to ensure they meet requirements for minimizing hallucinations and bias, preserving intellectual property rights, and maintaining appropriate confidentiality, integrity, and general security of data.

18.2 Secure AI Usage in Product Development

The purpose of this section is to establish guidelines and best practices for the secure development, deployment, and management of Artificial Intelligence (AI) systems within the company.

The company’s standards for AI development must include requirements for:

- Data Collection and Preprocessing
- Model Selection and Training
- Model Evaluation and Validation
- Model Deployment and Maintenance
- AI Model Explainability and Transparency
- Secure Coding Practices



Diligent may use AI tools, which include machine learning, generative AI and Large Language Models (LLM), to enhance the value that our products provide customers.

The AI models employed by Diligent should not be trained on customer data without the customer's consent. Furthermore, any content produced by Diligent's generative AI should be labeled, allowing users to readily identify AI-generated content.

As with all Diligent product functionality, controls must be in place to ensure the logical separation of customer data and no unauthorized third parties are provided access to customer data.

The training data and outputs of Diligent's product AI functions should be tested for reliability and trustworthiness.

19 Business Continuity Plan and Disaster Recovery Policy

The Company will document a plan to respond to a significant business disruption in a manner that prioritizes employee safety, safeguards company property, and protects client data.

The response includes an operational risk assessment, recovery and resumption of operations, and the return of customer access to the Company's services with minimal possible disruption. The Company will have the necessary personnel and resources available for both disaster preparation and disaster response. Personnel will be trained on the proper steps to be taken to enable the timely restoration of services.

Information security continuity must be embedded in the Company's business continuity management systems. Details can be found in the organization's continuity and recovery plans.

Business continuity plans must be reviewed, maintained, and tested regularly to ensure that business continuity plans are up-to-date, effective, and address information security requirements.

19.1 Data Backup

Only approved backup administrators are allowed to make backups of Company and customer data. Backups must be written to an alternate site, with sufficient redundancy to meet availability requirements, in accordance with the Company business continuity and disaster recovery plans.

Employees or contingent workers should utilize BTS approved software to ensure all Company data is properly backed up to avoid loss of Company data stored locally.



20 Information Security Reviews and Compliance

To avoid breaches of legal, statutory, regulatory, or contractual obligations related to information security and of any security requirements:

- All relevant statutory, regulatory, and contractual requirements must be explicitly defined, documented, and kept current for business-critical information systems at the Company.
- Appropriate processes must be implemented to ensure compliance with legislative, regulatory, and contractual requirements related to intellectual property rights and use of proprietary software products.
- Important business records, including any records that may be needed and/or required to be maintained for legal proceedings, must be protected from loss, destruction, alteration, and falsification to ensure compliance with legal, regulatory, contractual, and business requirements.
- All laws, regulations, and rules of Diligent regarding personal information must be complied with and appropriate controls must be implemented to comply with all relevant legal, regulatory, contractual, and business requirements.
- Appropriate controls must be in place to ensure compliance with all applicable laws and regulations related to managing access to or use of cryptographic controls.

20.1 Information Security Reviews

To ensure that information security is implemented and operated in accordance with the organizational policies and standards:

- The Company's approach to managing information security and its implementation (i.e., control objectives, controls, policies, processes and standards for information security) must be reviewed independently at planned intervals or when significant changes occur.
- Independent security reviews required to comply with regulatory or contractual requirements, such as GDPR, SOC, ISO 27001/2, HIPAA and FedRAMP (NIST 800-53) assessments (as required) must be planned for and conducted at least annually, or per the frequency required to maintain compliance.
- Responsible managers must ensure that all security requirements within their area of responsibility are met to achieve compliance with the Diligent Security Policy, relevant information security standards, and other documents relating to Information Security, as well as applicable regulatory and/or contractual requirements.
- Information Systems must be periodically assessed for compliance with applicable internal security standards and regulatory/contractual compliance requirements (e.g., ISO, SOC 2, FedRAMP). An internal continuous monitoring program shall be in place to ensure ongoing compliance with internal security standards and regulatory/contractual requirements (e.g., ISO, SOC 2, FedRAMP).

21 Policy Compliance and Enforcement

21.1 Annual Security Policy Acknowledgement

To emphasize the importance of complying with Security policies and each employee's role in protecting Company resources, intellectual property, and business data; all Company employees are required to sign an annual acknowledgement of the Company's Security Policies and Acceptable Use Policy. The acknowledgement will be included in the annual policy review and attestation process and will be stored with the employee's HR records.

21.2 Policy Enforcement

Any employee or contingent worker found to have violated these policies may be subject to disciplinary action, up to and including termination of employment.

Failure to observe copyright or license agreements may result in disciplinary action from the Company, up to and including immediate termination or legal action by the copyright owner.

Employees and contingent workers are individually accountable for the content of all text and attachments that they place in their email messages.

- Disciplinary actions that can be anticipated because of failure to observe security requirements include loss of access to company assets through to termination.
- Knowledge or reasonable suspicion of non-compliance of this policy must be reported immediately to SecurityNotify@diligent.com.

All Company managers are responsible for the enforcement and adherence of the Company's Security Policy within their departments. Failure to observe the policy may result in disciplinary action, up to and including termination depending upon the type and severity of the violation, whether it causes any liability or loss to the company, and/or the presence of any repeated violations.

The disciplinary process for employees who have committed a security breach includes:

- Appropriate evidentiary and legal standards to initiate investigations.
- Disciplinary proceedings that observe reasonable and legal requirements for due process and quality of evidence.
- Reasonable evidentiary and burden-of-proof standards to determine fault, that ensure correct and fair treatment for persons suspected of a breach.
- Sanctions that appropriately take into consideration factors such as the nature and gravity of the breach, its impact on operations, whether it is first or repeat offense, whether or not the violator was appropriately trained, whether or not the violator exercised due care or exhibited negligence.

22 Exceptions

All business lines and users are expected to comply with the Company's security policies and standards which are designed to establish the controls necessary to protect the Company's assets.

A control deficiency in one business process or resource can jeopardize other processes or resources because erroneous data may be inherited, privacy can be compromised or because a conduit for an intrusion into Company's systems may be created. However, there may be a case where compliance cannot be achieved for a variety of reasons. In such cases, an exception must be documented and approved using this process.

An exception to a published security policy, standard or practice may be granted in any of the following situations:

- Temporary exception, where immediate compliance would disrupt critical operations

- Another acceptable solution with equivalent protection is available
- A superior solution is available
- A legacy system is being retired and compliance is not possible (risk must be managed)
- Long-term exception, where compliance would adversely impact Company's business
- Compliance would cause a major adverse financial impact that would not be offset by the reduced risk occasioned by compliance (i.e., the cost to comply offsets the risk of non-compliance)

The exception request should document the following information where applicable:

- The specific policy/standard for which an exception is being requested
- The specific device, application or service for which the exception is being requested
- Data classification category of associated device, application or service
- The type of data that will be affected, either directly or indirectly, by the exception
- The nature of the non-compliance, i.e., specific deviation from the policy/standard
- Why an exception is required, e.g., what business need or situation exists, what alternatives were considered, and why are they are not appropriate
- Assessment of the potential risk posed by non-compliance, i.e., if the exception is granted
- Plan for managing or mitigating those risks, e.g., compensating controls, alternative approaches
- Anticipated length of non-compliance
- Plan to resolve the situation so that a policy exception will no longer be required
- Additional information as needed, including any specific conditions or requirements for approval

All requests for exception must be documented and approved by business line manager before security review.

All requests for exceptions must be risk assessed by the Security Team and approved by an appropriate Management stakeholder. All exceptions must be reviewed based on a consideration of the data classifications in scope and contractual and legal obligations.

Requests for exceptions are reviewed for validity and are not automatically approved. Requests for exception that create significant risk to the Company without compensating controls should not be approved. Requests for exception must be periodically reviewed to ensure that assumptions or business conditions have not changed. Renewals are not automatically approved. Requests for exception may be revoked in the event of a security incident or policy violation using established incident response procedures.

23 Appendix A - Related Documentation

This document references multiple external documents, such as policies, standards, and procedures. These documents will be available for relevant staff to view, and they will be reviewed periodically. The external documents referenced within this Policy are listed below.

23.1 Internal

Document Name	Document Type	Document Owner
Acceptable Use Policy *	Policy	Security
Background Check Policy	Policy	HR
Baseline Configuration Standard	Standard	Security - SecOps
Business Continuity Plan/Disaster Recovery Plan	Plan	ProdOps
Change Management Procedure	Procedure	ProdOps
Cybersecurity and Risk Management Committee Charter	Charter	Security - CISO
Recording Policy	Policy	Legal
Employee Handbook	Standard	HR
Encryption Standard	Standard	Security - AppSec
BTS Service Desk Onboarding Process New document: User onboarding and offboarding procedure	Procedure	BTS, HR, SRE and Security
BTS Device Wipe Policy	Policy	BTS
Firewall and Security Appliance Standard *	Standard	Security - SecOps
HR New Employee Hiring Procedures	Procedure	HR
Password Standard *	Standard	Security
Privacy Policy	Policy	Legal
Record Retention and Destruction Policy	Policy	Legal
Risk Assessment Methodology Standard	Standard	Security - CISO
Security Incident Response Plan	Plan	Security - SecOps
Secure-Software Development Lifecycle Standard	Standard	Security - AppSec
SIEM Log Retention Standard	Standard	Security - SecOps
Vulnerability Management Standard	Standard	Security - SecOps
User Offboarding Procedure	Procedure	BTS

Third Party Management Standard	Standard	Security - SecGRC
---------------------------------	----------	-------------------

23.2 External

Title	Origination Point
Australian Laws and Regulations Reference	Australia
GDPR	EU
CSC Top 20	USA
HIPAA	USA
CISA	USA
ISO 27001	ISO
NIST CSF	NIST
Various state or other governmental regulations	Various

24 Appendix B - Definitions

24.1 General Terms

Term	Definition
Must	This word, or the terms "REQUIRED" or "SHALL", mean that the statement is an absolute requirement of the specification.
Must Not	This phrase, or the phrase "SHALL NOT", means that the statement is an absolute prohibition of the specification.
Should	This word, or the adjective "RECOMMENDED", means that there may exist valid reasons in particular circumstances to ignore a particular item, but the full implications must be understood and carefully weighed before choosing a different course.
Should Not	This phrase, or the phrase "NOT RECOMMENDED" mean that there may exist valid reasons in particular circumstances when the particular behavior is acceptable or even useful, but the full implications should be understood, and the case carefully weighed before implementing any behavior described with this label.
May	This word, or the adjective "OPTIONAL", means that an item is truly optional. One vendor may choose to include the item because a particular marketplace requires it or because the vendor feels that it enhances the product while another vendor may omit the same item. An implementation which does not include a particular option MUST be prepared to interoperate with another implementation which does include the option, though perhaps with reduced functionality. In the same vein an implementation which does include a particular option MUST be prepared to interoperate with another implementation which does not include the option (except, of course, for the feature the option provides.)
Cybersecurity	The protection of internet-connected systems, including hardware, software and data, from malicious hackers or deliberate exploitation. Cybersecurity requires coordination of the following categories:

	Network Security, Application Security, Information Security, Operational Security, Disaster Recovery and Business Continuity, End-user Education.
Information Security	Information security is a set of strategies for managing the processes, tools and policies necessary to prevent, detect, document and counter threats to data in all forms including digital and non-digital information. It is designed to maintain the confidentiality, integrity and availability of data and is a subset of cybersecurity.
Security	The term Security encompasses Physical, Information Security and Cybersecurity domains. It includes the defense of digital information and IT assets against internal and external, malicious and accidental threats. This defense includes detection, prevention and response to threats through the use of security policies, software tools and IT services.
Information Systems	Any telecommunications and / or computer-related equipment or interconnected system or subsystems of equipment that is used in the acquisition, storage, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of voice and / or data (digital or analog): includes software, firmware, and hardware.
Computer Security Incident	An act or circumstance in which there is a deviation from the requirements of information security policies. Compromise, inadvertent disclosure, need-to-know violation, and administrative deviation are examples of security incidents, including any unauthorized activity that threatens the confidentiality, integrity or availability (CIA) of state information system resources
Breach	A security breach is defined as the unauthorized acquisition or access of computerized data that compromises the security, confidentiality, integrity of personal information maintained by the Company.
Contingent Workers	A contractor, consultant or temporary worker who is under direct management of Diligent. Employees of

	vendors or 3 rd parties not under direct management of Diligent are not part of this group.
--	--

24.2 Cloud Computing Definition

Term	Definition
Cloud Services	Any service made available to Diligent users, via the Internet that is not hosted at Diligent data centers, not on premise at any Diligent facility and not managed by Diligent. Diligent pays to use, rather than necessarily owns, the resources.
SaaS	Software as a Service is a model in which a third-party provider hosts applications and makes them available to Diligent over the Internet.
IaaS	Infrastructure as a Service is a model where a third-party provider supplies virtualized computing resources and supporting services to Diligent over the Internet.
PaaS	Platform as a Service is a model where a third-party provider delivers a computing platform of hardware and software tools to Diligent over the Internet, in many cases those needed for application development. A PaaS provider builds and supplies an environment on which users can install applications and data sets.

25 Appendix C - ISO Mapping

This section maps the Diligent Policy to the ISO 27001 clauses and Annex A controls.







25.1 ISO 27001:2022 Clauses and Controls Mapping

		Section
4	Context of the organization	
4.1	Understanding the organization and its context	External
4.2	Understanding the needs and expectations of interested parties	External
4.3	Determining the scope of the information security management system	External
4.4	Information security management system	External
5	Leadership	
5.1	Leadership and Commitment	2.3
5.2	Policy	2.2
5.3	Organizational roles, responsibilities and authorities	2.3; 2.4; 6.3
6	Planning	
6.1	Actions to address risks and opportunities	6
6.1.1	General	6; 6.1
6.1.2	Information security risk assessment	6.2, External
6.1.3 (d)	Statement of Applicability	External
6.1.3 (e)	Risk Treatment Plan	External
6.1.3	Information security risk treatment	6.1, External
6.2	Information security objectives and planning to achieve them	External
6.3	Planning of Changes	15; External
7	Support	
7.1	Resources	2.3
7.2	Competence	3.1
7.3	Awareness	3.4
7.4	Communication	External
7.5	Documented Information	External
7.5.1	General	External
7.5.2	Creating and Updating	External
7.5.3	Control of documented information	External
8	Operation	
10.1	Operational planning and control	External
10.1	Information security risk assessment	External
10.1	Information security risk treatment	External

9	Performance Evaluation	
9.1	Monitoring, measurement, analysis and evaluation	External
9.2	Internal audit	External
9.2.1	General	External
9.2.2	Internal audit programme	External
9.3	Management review	6.3, External
9.3.1	General	6.3; External
9.3.2	Management review inputs	External
9.3.3	Management review results	6.4; External
10	Improvement	
10.1	Continual Improvement	External
10.2	Nonconformity and corrective action	External
Annex A Control		Section
ID	Organizational controls	
5.1	Policies for information security	1; 2
5.2	Information security roles and responsibilities	2.3; 2.4; 6.3; 20
5.3	Segregation of duties	12.1
5.4	Management responsibilities	2.4; 3.1
5.5	Contact with authorities	External
5.6	Contact with special interest groups	External
5.7	Threat intelligence	External
5.8	Information security in project management	15.1
5.9	Inventory of information and other associated assets	10.1
5.1	Acceptable use of information and other associated assets	4
5.11	Return of assets	3.1; 10.1
5.12	Classification of information	5.3
5.13	Labelling of information	5.3
5.14	Information transfer	5.7
5.15	Access control	7
5.16	Identity management	7.1
5.17	Authentication information	7.3
5.18	Access rights	7.1
5.19	Information security in supplier relationships	11
5.2	Addressing information security within supplier agreements	11

5.21	Managing information security in the information and communication technology (ICT) supply chain	11
5.22	Monitoring, review and change management of supplier services	11
5.23	Information security for use of cloud services	8
5.24	Information security incident management planning and preparation	13; External
5.25	Assessment and decision on information security events	13; External
5.26	Response to information security incidents	13; External
5.27	Learning from information security incidents	13; External
5.28	Collection of evidence	13; External
5.29	Information security during disruption	19
5.3	ICT readiness for business continuity	External
5.31	Legal, statutory, regulatory and contractual requirements	20; External
5.32	Intellectual property rights	21; External
5.33	Protection of records	5.4, 5.5, External
5.34	Privacy and protection of personal identifiable information (PII)	5.5; 5.6; External
5.35	Independent review of information security	20.1; External
5.36	Compliance with policies, rules and standards for information security	21
5.37	Documented operating procedures	1; External
	People controls	
6.1	Screening	3.2
6.2	Terms and conditions of employment	3.1; 3.3
6.3	Information security awareness, education and training	3.4
6.4	Disciplinary process	21
6.5	Responsibilities after termination or change of employment	3.1
6.6	Confidentiality or non-disclosure agreements	3.3
6.7	Remote working	9.2
6.8	Information security event reporting	13; External
	Physical controls	
7.1	Physical security perimeters	9
7.2	Physical entry	9; 9.3
7.3	Securing offices, rooms and facilities	9.4
7.4	Physical security monitoring	9
7.5	Protecting against physical and environmental threats	9.1

7.6	Working in secure areas	9.4
7.7	Clear desk and clear screen	5.2
7.8	Equipment siting and protection	5.2; 9.2
7.9	Security of assets off-premises	5.2; 9.2; 10.2
7.1	Storage media	External
7.11	Supporting utilities	9.1; External
7.12	Cabling security	9.1; External
7.13	Equipment maintenance	10.1
7.14	Secure disposal or re-use of equipment	5.8; 10.1
	Technological controls	
8.1	User end point devices	5.4; 5.6
8.2	Privileged access rights	7.2; 7.4
8.3	Information access restriction	7
8.4	Access to source code	7.8; External
8.5	Secure authentication	7.3
8.6	Capacity management	16
8.7	Protection against malware	14.1
8.8	Management of technical vulnerabilities	14
8.9	Configuration management	External
8.1	Information deletion	5.4; External
8.11	Data masking	External
8.12	Data leakage prevention	External
8.13	Information backup	19.1
8.14	Redundancy of information processing facilities	External
8.15	Logging	12.2
8.16	Monitoring activities	External
8.17	Clock synchronization	12.2; External
8.18	Use of privileged utility programs	4.13; 4.15
8.19	Installation of software on operational systems	15; External
8.2	Networks security	12; 12.1
8.21	Security of network services	12; 12.1
8.22	Segregation of networks	12.1
8.23	Web filtering	4.19
8.24	Use of cryptography	5.6; External

8.25	Secure development life cycle	17; External
8.26	Application security requirements	17; External
8.27	Secure system architecture and engineering principles	17; External
8.28	Secure coding	17; External
8.29	Security testing in development and acceptance	17; External
8.3	Outsourced development	17; External
8.31	Separation of development, test and production environments	12.1
8.32	Change management	15
8.33	Test information	17; External
8.34	Protection of information systems during audit testing	External

Acknowledgement and Certification

The undersigned does hereby acknowledge receipt of the Security Policy. The undersigned has read and understands (or has had explained) the Security Policy and agrees to be governed and abide by the Security Policy at all times.

(Signature)

(Please print name)

(Date)